VŠB TECHNICKÁ UNIVERZITA OSTRAVA

VSB TECHNICAL UNIVERSITY OF OSTRAVA

www.vsb.cz

VŠB TECHNICKÁ UNIVERZITA OSTRAVA | FAKULTA ELEKTROTECHNIKY A INFORMATIKY

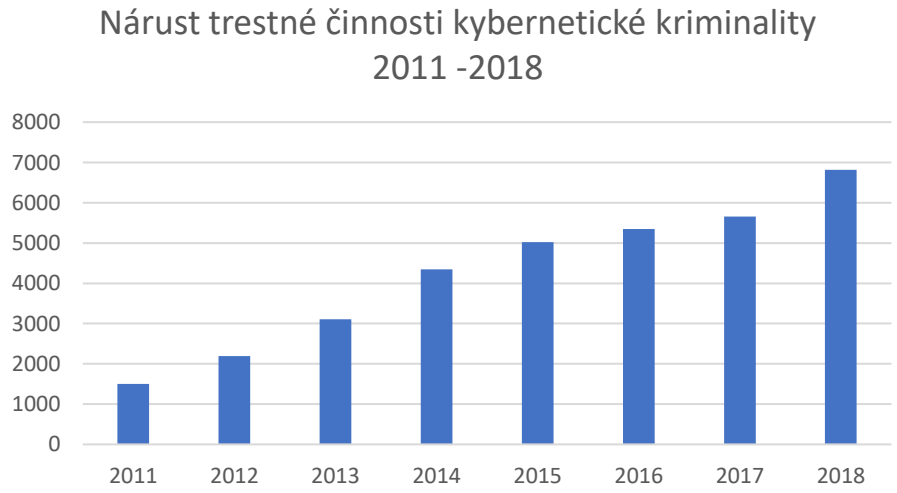
Bezpečnost ve firemním i osobním kyberprostoru

(peníze vládnou světu)

Ing. Jan Plucar, Ph.D.

Kyberprostor – svět informací a hrozeb

- Kyberprostor je tam, kde jsou informace, jedná se o skutečný a zároveň fiktivní prostor.
- V roce 2018 nárůst kyberkriminality o **450%** oproti roku 2011. (zdroj: policie.cz)



Kyberprostor – svět informací a hrozeb

73% of IT security decision makers are concerned about the digital attack surface.

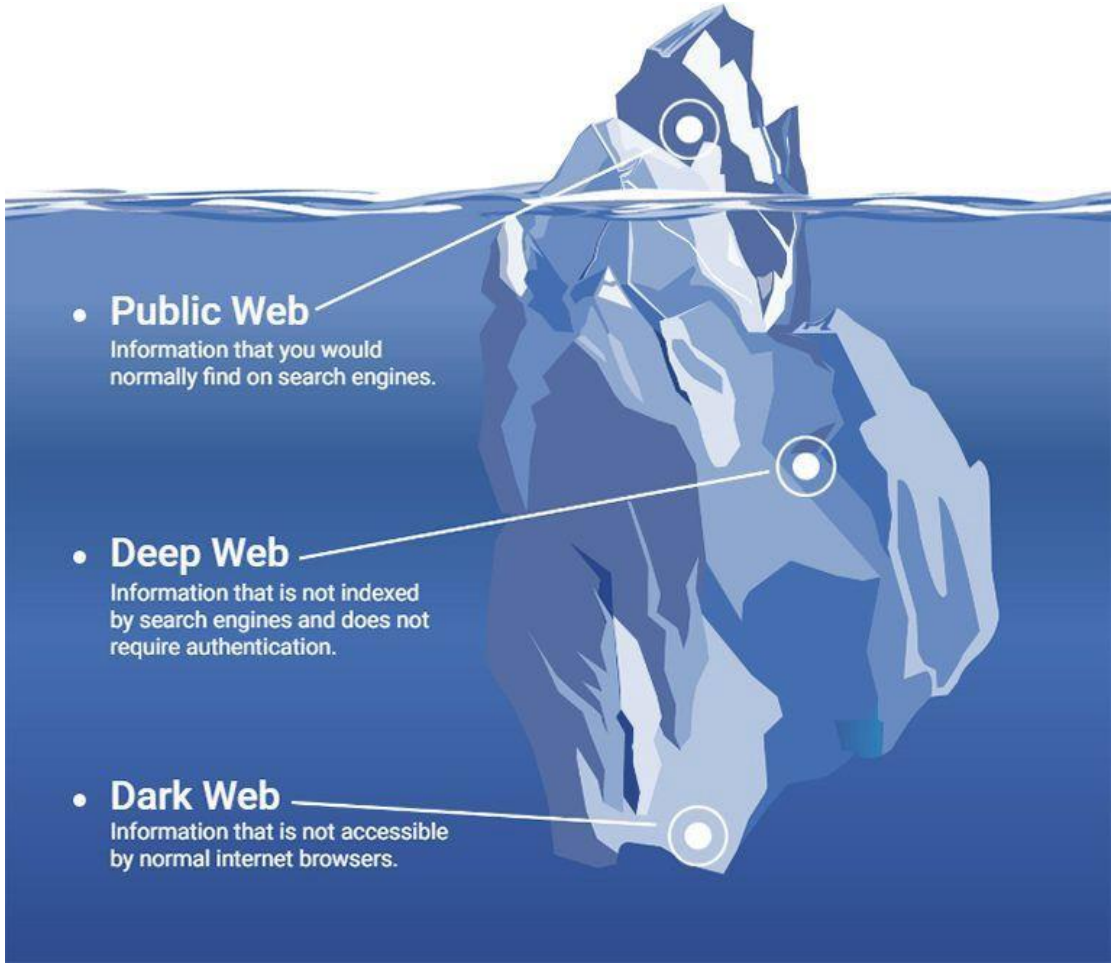
43% argue that the attack surface is spiraling out of control.

37% describe the attack surface as constantly evolving and messy.

Figure 1. A survey of 6,297 IT security decision-makers reveals that a significant number of them are concerned about the digital attack surface.

Source: Trend Micro survey in partnership with Sapio Research

Kde se pohybujeme?



Převzato: https://cyberops.in/blog/wp-content/uploads/2018/10/tor-network.jpg

Nabízené služby I

Uživatelské účty:

- Dárkové poukazy na offline služby: **15-40%** původní hodnoty
- Dárkové poukazy do eshopů: **15-50%** původní hodnoty
- Herní účty: **0.5 -12$**
- Emailové účty (2500): **1-15$**
- Přihlašovací údaje na RDP: **3-30$**
- Účet pro online platby: **1-100$**

Citlivé informace:

- Ukradená nebo falešná identita (jméno, Rč/SSN, bydliště)**: 1.5$**
- Falešný pas, řidičský průkaz, etc.: **25 -5000$**
- Naskenovaná vyúčtování (elektřina, plyn, nájem): **0.50 – 45$**
- Naskenované doklady (občanský a řidičský průkaz, pas, etc.): **1 – 35$**

Nabízené služby II

Malware:

- Generátor makra pro MS Office: **5 – 10$**
- DDoS bot software: **1 – 15$**
- Spyware: **3 – 50$**
- Cryptocurrency stealer: **4 – 60$**
- Cryptocurrency miner: **10 – 200$**
- Ransomware toolkit: **0 – 250$**

Služby:

- Hacker na pronajmutí: **100$**
- DDoS služba na krátké období (méně než hodina): **5 – 20$**
- DDoS služba na delší období (účtováno za den): **10 – 1000$**

Formjacking

Metoda Formjackingu využívá JavaScript kódu pro krádež údajů o kreditních kartách a dalších informací z platebních formulářů na stránkách elektronických obchodů – trend 2018/2019.

Fakta:

- V průměru bylo **měsíčně** detekováno **4850 unikátních webových stránek** s touto infekcí
- Pokud by z každé napadené stránky bylo ukradeno **10 záznamů kreditních karet**, tak průměrný výdělek z prodeje na černém trhu činí **2.2 milionu dolarů**
- Nejčastěji jsou napadané **středně malé online obchody** s oblečením, elektronikou, etc.

Incidenty:

- British Airways, Srpen 2018: ukradeny informace o 380 000 zákaznících (jména, bydliště, čísla karet, security kód, expirace karty)
- Ticketmaster, 2016-2018: napadeno na 800 webových obchodů využívajících Ticketmaster přeprodejního systému.

Cryptojacking

Zločinci se pokoušejí spustit škodlivý kód na zařízení obětí bez jejich vědomí a využít tak prostředků zařízení oběti k těžbě kryptoměn.

Fakta:

- Hlavní aktivita od konce roku **2017 – 2019**. V roce 2018 zablokovala společnost Symantec **69 miliónu pokusů** o cryptojacking
- Programy pro těžbu kryptoměn využívající prohlížeče umožňují kybernetickým zločincům cílit i aktualizované operační systémy
- Velice náročné na detekci

Incidenty:

- Útok na weby využívající Wordpress, 2017 - 2018: během hodiny přišlo na **14 miliónů** škodlivých požadavků z **10 000** unikátních IP adres s pokusem napadnout **190 000** wordpress stránek. V průběhu útoku bylo vytěženo Monero v hodnotě **100 000$**
- Skupina stojící za Venus Lockerem přešla v roce 2018 na šíření Monero mineru

Ransomware

Škodlivý kód se pokusí po infekci počítače nalézt klíčové soubory uživatele, ty zašifruje a od uživatele vyžaduje výkupné.

Fakta:

- Většina hlavních ransomware rodin cíluje počítače se systémem Windows. Objevují se však případy, které napadají Cloudová uložiště.
- Ověřená technologie, nové verze Ransomwaru vychází z léty ověřených malwarových rodin
- Průměrná výše výkupného činí 500$, ve většině případů splatné v kryptoměně Monero či Bitcoin

Incidenty:

- SamSam skupina, 2018: v průběhu roku bylo napadeno 67 organizací, které dohromady zaplatily výkupné ve výši 6 miliónů dolarů a zaznamenaly celkovou ztrátu 30 miliónů dolarů
- Locky na VŠB-TU, 2017-2018: napadeno několik akademiků prostřednictvím emailového phishingu

Linux Based Ransomware

- V první polovině roku 2022 jsme zaznamenali 75% nárůst útoků ransomwaru na počítače se systémem Linux.
- V říjnu 2021 oznámili provozovatelé LockBitu na darkwebu novou variantu cílenou na Linux zařízení, LockBit Linux-ESXi.
- V květnu 2022 byla nalezena nová varianta ransomwaru s názvem Cheerscrypt zaměřená na zařízení používající ESXi.

Hugh Aver. (March 26, 2021). Kaspersky. “Ransomware in a virtual environment.” Accessed on July 25, 2022, at https://www.kaspersky.com/blog/ransomware-in-virtual-environment/39150/

Arianne Dela Cruz et al. (May 25, 2022). Trend Micro. “New Linux-Based Ransomware Cheerscrypt Targeting ESXi Devices Linked to Leaked Babuk Source Code.” Accessed on July 25, 2022, at https://www.trendmicro.com/en_us/research/22/e/new-linux-based-ransomware-cheerscrypt-targets-exsi-devices.html

Supply chain attack

Napadení dodavatelského řetězce, kterému uživatel důvěřuje.

Fakta:

- **Instalace** škodlivého softwaru do zařízení již v **továrnách**
- **Instalace** škodlivého softwaru do zařízení u **přeprodejce**
- **Napadání** špatně zabezpečených **serverů partnerů a trojanizace prostředků**

Incidenty:

- CCleaner, konec roku 2017: využití populárního programu pro infekci **2.27 miliónů zařízení**
- M.E.Doc, konec roku 2017: napadení aktualizačního serveru **daňového programu**. Účelem byla **krádež informací** a zahlazení stop pomocí Petya/NotPetya

Rusko – Ukrajinský konflikt

Conti ransomware group

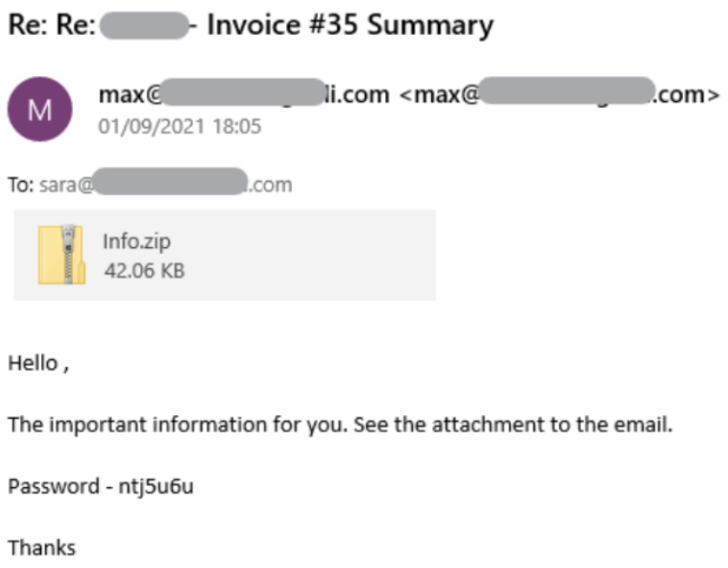
- **Conti:** nechvalně proslulá skupina provozující ransomware kampaně s možnými vazbami na ruskou rozvědku, která je známá útoky na poskytovatele zdravotní péče a stovky dalších cílů.

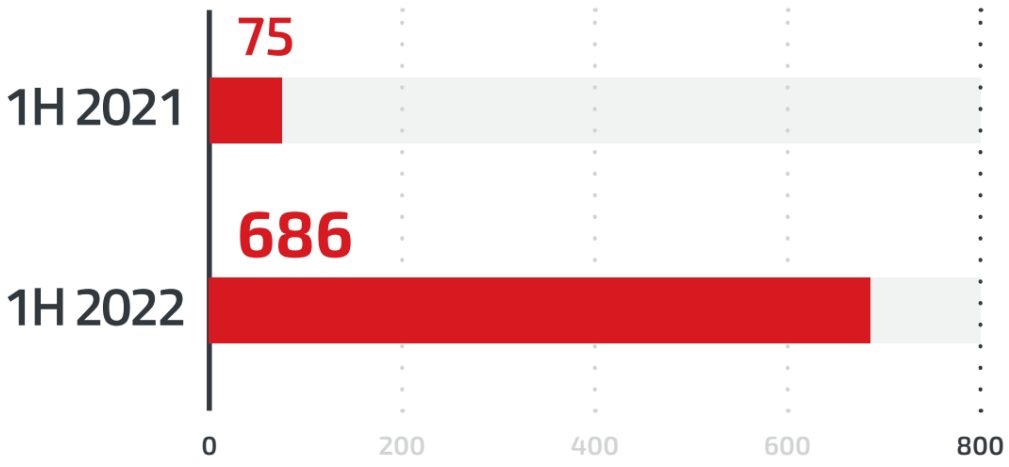
- Podle Agentury pro kybernetickou bezpečnost a bezpečnost infrastruktury (CISA) ministerstva vnitřní bezpečnosti a FBI byl ransomware **Conti součástí více než 400 útoků** na převážně americké cíle v období **od jara 2020 do jara 2021**.

Bazar Loader

- **Bazar Loader** je bezsouborový útok, který se stahuje přes zadní vrátka a umožňuje útočníkům instalovat další malware, často používaný pro útoky ransomwaru. Od svého vzniku v dubnu 2020 Bazar Loader napadl celou řadu organizací v Severní Americe a Evropě. Obecně se předpokládá, že Bazar Loader vyvinula skupina hackerů známá jako Trickbot.

- Bazar Loader obvykle **využívá existující "e-mailovou" korespondenci**. "Odpovídá" na skutečné e-mailové vlákno se škodlivým obsahem a zároveň používá triky sociálního inženýrství, aby vypadal legitimně a nalákal oběť.





Zvýšená detekce Bazar Loaderu 2022

Bazar Loader

1. **Obvykle je k e-mailu přiložen soubor ZIP**, který vyžaduje heslo. Samotné heslo je uvedeno v těle e-mailu. Z pohledu útočníka je důvodem pro použití souboru chráněného heslem snaha ztížit bezpečnostním řešením skenování souboru.

2. Otevření souboru **ZIP vede k souboru Microsoft Word**. V samotném souboru .doc se zobrazí zpráva **požadující spuštění makra** pro zobrazení souboru.

3. **Soubor obsahuje malý skrytý text - jedná se o obsah souboru HTA (aplikace HTML)**. Ve výchozím nastavení se soubory s příponou HTA spouštějí prostřednictvím mshta.exe - nástroje, který je již k dispozici a podepsán systémem Windows.

4. **HTA** se pak spustí a **komunikuje se serverem útočníků**. **Server vrátí škodlivý soubor DLL**.

5. **V tomto okamžiku se soubor DLL, který realizuje zadní vrátka do systému spustí a umožní komunikaci se serverem.**

https://www.linkedin.com/pulse/microsoft-office-zero-day-detecting-hta-handler-kevin-douglas

Chcete pomoct finančním darem?

Ukraine / Україна
@Ukraine

Stand with the people of Ukraine. Now accepting cryptocurrency donations. Bitcoin, Ethereum and USDT.

BTC - 357a3So9CbsNfBBgFYACGvxxS6tMaDoa1P

ETH and USDT (ERC-20) - 0x165CD37b4C644C2921454429E7F9358d18A45

8:59 PM · Feb 26, 2022 · Twitter for iPhone

59.3K Retweets **13.7K** Quote Tweets **216.6K** Likes

Help ukraine Home Donate Latest donations

What happened to Ukraine?

Ukraine was viciously invaded by Russian troops on **24/2/2022** for the president's personal philosophy and gains. They have mercilessly targeted our people and our infrastructure without any regards to human life. We as a country request you for your support and prayers so that we can survive this war.

Want to donate?

Each donations helps tremendously for our war efforts to keep our people safe and ready to defend ourselves from the Russian aggressors.

Help with **Bitcoin**
If you want to help Ukraine, please send any amount on the address bellow. Thank you!
bc1q7zzvpswsk27r8m7aysv54w2fyyxuc2h4c6f4ej
Last donation 1 hours ago

Help with **Ethereum**
If you want to help Ukraine, please send any amount on the address bellow. Thank you!
0x75Ac412E69bC864c830C40E222aCd68E88aE40cE
Last donation 7 minutes ago

Help with **USDT (ERC-20)**
If you want to help Ukraine, please send any amount on the address bellow. Thank you!
0xaB353eC658C946E0F2caDcceE8C756b878003984
Last donation 8 minutes ago

Help with **Litecoin**
If you want to help Ukraine, please send any amount on the address bellow. Thank you!
Ldt5rj2jnwE5rHPBgpGm2ht TFBJ6iwYpGX
Last donation 9 minutes ago

Latest donations

All latest donations will be shown on random order for the privacy and safety of the donators. Thank you for helping us through these dark times!

Donation with amount of **101$** to the address bc1q7zzvpswsk27r8m7aysv54w2fyyxuc2h4c6f4ej. This transaction hash is 0a3225bcbb7932...
1 minute ago

Donation with amount of **32$** to the address bc1q7zzvpswsk27r8m7aysv54w2fyyxuc2h4c6f4ej. This transaction hash is 9d64d25244daaa...
12 hours ago

Donation with amount of **0.20$** to the address Ldt5rj2jnwE5rHPBgpGm2ht TFBJ6iwYpGX. This transaction hash is c36992d389d754...
6 minutes ago

Donation with amount of **144$** to the address 0xaB353eC658C946E0F2caDcceE8C756b878003984. This transaction hash is 4a34c1c0115229...
37 minutes ago

Thank you!

Your donations help us a lot and are a pivotal role in this war. Please keep us in your prayers and hope for a safe ending for our people.

#freeukraine

Ukraine Crises - Mozilla Thunderbird

File Edit View Go Message Tools Help

Get Messages Write Chat Address Book Tag

From Support Ukraine <support@donateukrainenow.org>

Subject **Ukraine Crises**

To [redacted]

Reply Reply All Forward More

6:01 am

ABOUT US DONATE NOW

Donate Now Help Relocate More

Thousands of Ukrainians are fleeing the country and seeking safety in neighboring nations. Our purpose is to assist in the relocation of more people to safer areas.

DONATE NOW

Chcete pomoct finančním darem?

lidovky.cz
https://www.lidovky.cz › domov › domy-ukrajina-fale...

Objevují se falešné sbírky na pomoc Ukrajině. Podvodníci ...

2. 3. 2022

idnes.cz
https://www.idnes.cz › zpravy › domaci › penize-sbirky-...

Slušné i falešné sbírky na Ukrajinu. Dohledat, kam vaše ...

17. 5. 2022

denik.cz
https://www.denik.cz › Česko

Pozor na falešné sbírky na Ukrajinu, peníze mohou posílat i ...

25. 2. 2022

mobilizujeme.cz
https://mobilizujeme.cz › clanky › podvodnici-zneuzi...

Podvodníci zneužívají války na Ukrajině! Vydávají se za ...

27. 2. 2022

Případ premianta

Scénář

Prostředí:

- Gymnázium, žáci **12-19 let**
- Tři počítačové učebny, **50 počítačů**
- Lektoři využívají notebooky pro práci z domu, **10 notebooků**
- **Data** uložena na **centrálním serveru**

Počítačová ochrana:

- **Uživatelé** mají nastavené účty s **různými právy**
- **Právo instalovat** aplikace mají pouze **správci** a **administrátor**
- Každý počítač je chráněn **antivirovým nástrojem**
- Akce uživatelů se **logují**
- Dohled provádí **odborná IT firma**, 15 000Kč/měsíc

Problémy

- Lektoři si stěžují na **podivné chování** počítačů. Ze soukromých složek na serveru **mizí připravené lekce, testy a domácí úkoly**
- Na některých počítačích se nedá pracovat, jsou nějaké **zpomalené**
- **Server je** neustále **plný** a správci jej musí pořád mazat
- Ředitel si stěžuje, že mu počítač hlásí, že na jeho notebooku **není nainstalován antivir**
- Při práci z **domu** se často stává, že je **uživatel odhlášen** ze systému

Výsledek šetření

- Skupina tří žáků (12-13 let) si zakoupila hardwarový Keylogger, který následně použila pro získání přihlašovacích údajů správců
- Ukradené údaje využívali asi půl roku. Chybou byla instalace Monero mineru
- Obtížnost útoků je téměř nulová a náklady se pohybují mezi 5 - 10$

Případ bílého koně

Scénář

Prostředí:

- Malá soukromá firma o **třech** zaměstnancích. Každý má vlastní PC
- Počítače jsou propojeny **jednoduchou sítí**
- Obchodní zástupci **cestují po světě**, ale **bez notebooků**
- Obchodní partneři z **Ruska, Ukrajiny, Číny**

Počítačová ochrana:

- **Uživatelé** mají nastavené účty s **administrátorskými právy**
- Na počítačích je stále nainstalován **Windows XP**
- Na počítačích je nainstalován **archaický antivirový program**
- Router je ponechán v **továrním nastavení**, byla pouze zřízena **Wifi síť chráněná heslem**
- **O počítače se stará patnáctiletý syn kamaráda**

Problémy

- Jeden z obchodních zástupců přijal **email informující o změně bankovního spojení** jednoho ze stálých **dodavatelů**
- O několik dní později přichází do firemní schránky email se **zálohovou fakturou**. Obchodní zástupce podobnou **fakturu očekává**, a tak ji **proplácí**. **Pro jistotu kontroluje**, že faktura obsahuje již **nové číslo účtu**
- **Následující den** přichází **další zálohová faktura**, tentokrát se **starým číslem účtu**
- Po **telefonátu** dodavateli se dochází ke **zjištění**, že **zaplacená** zálohová faktura **nepatří dodavateli**

Výsledek šetření

- **Policie Čr** po šesti měsících **případ odkládá**. Odeslané peníze jsou **přeposílány** mezi **zeměmi**, které **nejsou ‚flexibilní‘** v mezinárodní **spolupráci**
- Dle informací patří **konečný účet** těžce **postižené osobě z Albánie**
- S velkou jistotou došlo k **zachycení** emailové **komunikace** mezi dodavatelem a objednatelem
- Možností zachycení emailové komunikace je mnoho, pravděpodobná je **infiltrace emailové schránky**

Případ výhodného nákupu televizoru

Scénář

Prostředí:

- Zákazník si chce **pořídit novou TV**.
- Na internetu si našel recenze a vybral si příhodný model.
- Jako rozumný spotřebitel **využil server Heureka**, aby vyhledal **nejlepší nabídku**.
- Z vybraných nabídek zvolil tu, kterou nabízel **velmi dobře hodnocený obchod** a byla **cenově nejlepší**.
- Jako bonus nabízel E-shop zajímavou akci. V případě **platby předem** bude TV zástupci obchodu dopravena až do bytu, kde bude zapojena a vyzkoušena.

Problémy

- **Zákazník částku zaplatil**, ale ani po týdnu se mu **nikdo neozval** s termínem dodání TV.
- **Webové stránky** E-shopu **se staly nedostupné**.
- **Na telefonní číslo** z potvrzení o provedené platbě **se nedá dovolat**.

Výsledek šetření

- **Zákazník kontaktoval Policii Čr.** Ta jej informovala, že podobných případů eviduje v posledních dvou týdnech desítky.
- Během několika týdnů vystoupala **celková škoda k 10 miliónům** korun!
- **Podvodníci** si za použití jednoduché šablony **založili nový E-shop**. Firma vlastnící E-shop nikdy neexistovala.
- **Podvodníci naplnili E-shop zbožím**. Zřejmě **pomocí jednoduchého crawleru načetli ceny konkurence**, které mírně ponížili.
- **Na černém trhu si zaplatili službu pro získání pozitivních recenzí E-shopu**.

Kde hledat

- https://www.nukib.cz/cs/kyberneticka-bezpecnost/vyzkum/publikace-k-vyzkumu/
- https://www.crowdstrike.com/resources/reports/global-threat-report/
- https://www.sophos.com/en-us/labs/security-threat-report
- https://www.enisa.europa.eu/publications/enisa-threat-landscape-2021
- https://www.mcafee.com/enterprise/en-us/threat-center/mcafee-labs/reports.html
- https://www.sonicwall.com/2022-cyber-threat-report/
- https://www.ncsc.gov.uk/section/keep-up-to-date/threat-reports?q=&defaultTypes=report&sort=date%2Bdesc

Děkuji za pozornost

Ing. Jan Plucar, Ph.D.
Skupina Cyber Security VSB